SECCIÓN 4.2

Malware y amenazas vistas desde el comportamiento

Temas de esta sección:

- Por qué mirar comportamiento y no solo el nombre del malware
- Una alerta aislada no cuenta toda la historia
- De evento aislado a secuencia completa
- Qué revisar en endpoint, red, DNS e identidad
- Señales de ejecución, persistencia, C2, robo de credenciales e impacto
- Cómo documentar comportamiento correctamente

4.2 | De evento aislado a secuencia completa

Una alerta aislada puede ser ambigua. La secuencia completa cambia el análisis:

1	Usuario abre documento adjunto
2	WINWORD.EXE ejecuta powershell.exe
3	PowerShell usa parámetro -enc (comando codificado)
4	PowerShell conecta a dominio externo
5	Se descarga update.exe
6	update.exe se ejecuta desde C:\Users\Public\
7	Se crea una tarea programada
8	El host inicia conexiones cada 60 segundos

Ejecución inicial → descarga de payload → persistencia → posible C2. La primera línea era ambigua. La secuencia completa es clara.

El análisis de comportamiento necesita múltiples fuentes. Cada una aporta una pieza:

ENDPOINT (EDR)

- Proceso ejecutado y proceso padre
- Línea de comandos
- Ruta del ejecutable (firma, hash)
- Archivos creados o modificados
- Persistencia: tareas, registro, servicios
- Conexiones de red generadas

RED

- Dominio/IP destino y reputación
- Puerto y protocolo
- Frecuencia y volumen
- Si la conexión fue permitida o bloqueada
- Si ocurrió después de ejecución sospechosa
- Tráfico interno anómalo

DNS

- Dominio recién observado en el entorno
- Muchos NXDOMAIN (posible DGA)
- Consultas antes de conexión sospechosa
- Subdominios largos (posible tunneling)
- Varios hosts consultando mismo dominio raro

IDENTIDAD

- Login desde ubicación inusual
- MFA exitoso pero fuera de patrón
- Regla de reenvío de correo creada
- Descarga masiva de archivos
- Nuevo método MFA o token OAuth
- Acceso a aplicaciones sensibles

4.2 | Señales por etapa: ejecución, persistencia, C2, robo e impacto

Cada etapa del ataque genera señales distintas. Reconocerlas permite ubicar al atacante en la cadena:

EJECUCIÓN	WINWORD→powershell.exe · script desde Temp · archivo en Downloads ejecutado · proceso hijo inesperado de Office · -enc / -nop / -hidden
PERSISTENCIA	Run Key creada · tarea programada con binario en ruta pública · nuevo servicio · regla de correo · nuevo método MFA · LNK en Startup
C2	Beaconing periódico · dominio nuevo o con baja reputación · HTTPS desde proceso no firmado · DNS a subdominio aleatorio · tráfico a CDN o repositorio
ROBO DE CREDENCIALES	Acceso a Chrome Login Data / Cookies · LSASS dump · acceso a Credential Manager · Mimikatz · creación de zip con datos de login
IMPACTO	Cifrado masivo de archivos · eliminación de shadow copies · MBR modification · servicios detenidos · ransom note creado · datos eliminados

⚠ *No todas las etapas siempre aparecen. Un atacante puede saltar de ejecución directamente a impacto. Buscar señales de cada etapa ayuda a ubicar la actividad en la cadena.*

Mismo comportamiento base: PowerShell descarga un archivo desde internet. Tres interpretaciones posibles:

LEGÍTIMO	SOSPECHOSO	MALICIOSO PROBABLE
• Usuario de IT • Ticket aprobado • Destino corporativo conocido • Script documentado • Host administrativo	• Usuario no técnico • Proceso padre: Word • Dominio externo desconocido • Archivo se guarda en AppData • Hay conexión periódica posterior	• Descarga un ejecutable • Lo ejecuta • Crea persistencia • Conecta a dominio externo raro • Hay otros hosts afectados

La clasificación depende de la evidencia, no de la herramienta. La misma acción técnica puede tener tres interpretaciones distintas según usuario, proceso padre, destino y actividad posterior.

Documentación insuficiente:

```
"Se detectó malware."
```

Documentación correcta:

```
Se observó ejecución de invoice_update.exe desde la carpeta Downloads del usuario compras.vera. Luego el proceso
creó un archivo en AppData, generó una tarea programada y comenzó conexiones HTTPS periódicas hacia
sync-check-cloud.net. La secuencia es compatible con ejecución de archivo sospechoso, persistencia y posible
comunicación externa. Se recomienda escalamiento.
```

Una buena documentación debe incluir:

- Qué ocurrió y en qué orden
- Qué evidencia existe
- Por qué es relevante
- Qué hipótesis se plantea
- Qué acción se recomienda